攻击示例中探索目标网站一系列信息如网络结构，服务器功能、端口等的一系列小工具的作用及试探的顺序？

这些工具用于攻击前的信息收集与扫描。

- Whois：获取 IP 段信息
- Cheops-ng：探测网络拓扑、主机分布
- Nmap：扫描端口、识别服务
- Firewalk：探测防火墙策略
- Nessus：扫描系统漏洞
- Wellenreiter：扫描无线接入点，伪造 MAC 接入
- Paros Proxy：扫描 Web 应用层漏洞
- THC Hydra：爆破弱口令

【问：攻击者通常以什么顺序探索目标？】

侦察　　扫描　　获取访问　维持访问　掩盖踪迹

云计算中虚拟机面临的安全威胁及防御措施。

云计算中虚拟机面临的安全威胁主要包括：
虚拟机逃逸、虚拟机间侧信道攻击、Hypervisor 被攻陷、镜像污染、快照泄露、虚拟机迁移被劫持、共享资源滥用、虚拟网络攻击，以及虚拟机生命周期管理不当等。
防御措施包括：
强化 Hypervisor 安全（及时打补丁、减少攻击面）、采用硬件虚拟化安全扩展（如 SEV/TDX）、加密虚拟机内存和迁移流量、隔离不同租户虚拟机、加强虚拟网络安全（VLAN/微分段）、对镜像签名与扫描、加密快照与存储卷、强化虚拟机自身安全及零信任访问控制、加强监控审计等

大数据技术带来哪些安全挑战？

1. 数据量巨大导致集中泄露风险；
2. 数据类型多样（图像/文本/日志）导致敏感信息难识别；
3. 分布式节点多、攻击面大，通信链路易被劫持；
4. 大数据平台（Hadoop/Spark）默认配置不安全、权限管理复杂；
5. 恶意任务可能注入，导致数据篡改或集群资源被滥用；
6. 隐私泄露严重，去匿名化容易，难满足法规（如 GDPR）要求；
7. 模型训练过程中存在数据投毒、模型反推等 AI 安全风险；
8. 日志、快照、缓存等附带数据极易泄露敏感信息。

APT攻击的过程，在攻击的每个环节有哪些具体的手段

1. 侦察：
   利用社会工程学、Whois、DNS、公开信息、垃圾收集等获取情报。
2. 扫描：
   使用 Nmap、Firewalk、Nessus 等工具扫描主机、端口、服务和漏洞。
3. 获取访问：
   通过漏洞利用（缓冲区溢出、未打补丁漏洞）、Web 攻击（SQL 注入、XSS）、弱口令破解、钓鱼邮件、供应链攻击等方式进入系统。
4. 维持访问：
   部署木马、后门、Rootkit，进行横向移动、权限提升，持续保持控制。
5. 数据收集与外传：
   收集敏感数据，通过加密通道、DNS/HTTP 隧道等方式外传信息。
6. 掩盖踪迹：
   删除日志、修改时间戳、隐藏进程文件，保持隐蔽性。

安全性的目标和威胁、防御技术（第2章 加密和认证部分）

1. 安全性的目标包括：
   机密性、完整性、不可否认性、鉴别、可用性和审计性。
2. 针对这些目标的典型威胁有：
   数据暴露、数据篡改、抵赖、身份伪造、拒绝服务、不可审计等。
3. 常用防御技术包括：
   对称加密/公钥加密保证机密性；
   哈希与数字签名保证完整性与不可否认性；
   数字证书保证身份认证；
   防火墙、IDS、杀毒软件保证可用性；
   日志审计保证可追踪性

公钥算法的三种用法：加密、认证、认证加密，每个用法用的哪个公钥私钥

加密：接收者公钥加密 → 接收者私钥解密
认证：发送者私钥签名 → 发送者公钥验证
认证 + 加密：先发私钥签名，再收公钥加密

散列函数、数字签名和数字证书的工作原理，算法有何关联？什么是字典攻击？

散列函数：将任意长度数据映射为固定长度摘要，具有不可逆性和抗碰撞性，用于完整性校验和数字签名。
数字签名：对消息摘要使用发送者私钥加密，接收者用发送者公钥验证，实现身份认证、完整性和不可否认性。
数字证书：CA 使用自己的私钥对用户公钥和身份信息签名，用以证明该公钥的合法性，是 PKI 的核心。
三者关系：散列函数用于摘要，数字签名对摘要加密，数字证书用于认证数字签名中的公钥。
字典攻击：攻击者使用常见密码词典逐项尝试登录或匹配 Hash，用于破解弱口令和弱 Hash。

操作系统有哪些软硬件安全机制？这些机制的主要保护目的是什么？有哪些自主访问控制和强制访问机制？两种多级（强制）访问控制机制各自有什么特点，用在什么场景？

操作系统的硬件安全机制包括：
（1）CPU 特权级与特权指令
（2）内存保护（MMU、虚拟内存、不可执行页）
（3）I/O 保护
（4）中断/陷阱机制
（5）计时器防止 CPU 被独占
（6）TPM、Secure Boot 等可信启动
软件安全机制包括：
（1）身份认证（密码、MFA）
（2）访问控制（DAC/MAC/RBAC）
（3）文件系统权限与加密
（4）进程隔离与系统调用控制
（5）日志审计
（6）补丁管理与反恶意软件
（7）沙箱与虚拟化

操作系统的软硬件安全机制主要用于实现：
• 隔离性（阻止进程之间互相干扰）
• 访问控制（只允许授权主体访问资源）
• 系统完整性（防止代码、内存、内核被篡改）
• 可用性保障（防止资源被滥用导致瘫痪）
• 审计性（记录行为以便追踪责任）

目的：实现系统的机密性、完整性、可用性、可控性和可审计性。

自主访问控制机制：Unix/Linux 的 r/w/x 文件权限、ACL（访问控制列表）、Windows DACL、能力表（Capabilities）、应用层访问权限（如数据库权限）。
强制访问控制（MAC）机制：
Bell-LaPadula 模型、Biba 模型、MLS 多级安全、SELinux、AppArmor、FreeBSD MAC、Windows MIC（完整性控制）

模型	关注点	访问规则	防护目标	典型应用场景
Bell–LaPadula（BLP）	机密性	禁止向上读（No Read Up）禁止向下写（No Write Down）	防止泄密	军事、情报、政府涉密系统
Biba 模型	完整性	禁止向下读（No Read Down）禁止向上写（No Write Up）	防止数据被污染	金融、医疗、工控、供应链系统

恶意软件的分类（两种分类: 传统方法，MSF分类法），病毒和蠕虫的区别，PE文件格式的一些关键点（如在003CH开始指向PE的起始地址）

恶意软件传统分类：病毒、蠕虫、木马、Rootkit、Botnet、广告软件、间谍软件、勒索软件等。
MSF 分类：辅助模块、漏洞利用模块、后渗透模块、Payloads、编码器、Nops。
病毒 vs 蠕虫：病毒依赖宿主文件并手动传播；蠕虫独立运行并通过网络自动传播。
PE 文件关键：在 DOS 头的偏移 0x3C 处存放 e_lfanew，其指向 PE Header 起始；关键字段包括 AddressOfEntryPoint、ImageBase、SectionAlignment 等。病毒感染常修改入口点、添加节、重定位和动态获取 API。

编写PE文件病毒的关键技术；映像头中几个关键地址如AddressOfEntryPoint，ImageBased有什么作用?

编写 PE 文件病毒的关键技术包括：

1. 病毒重定位技术：通过 CALL 获取 EIP、基址+偏移访问，使病毒在不同加载地址均能正确运行。
2. API 自获取技术：不修改导入表，而是动态找到 kernel32.dll 基址，通过解析导出表获取 GetProcAddress/LoadLibraryA，再加载所需 API。
3. 目标文件遍历技术：使用 FindFirstFile/FindNextFile 搜索磁盘中的 EXE/DLL，检查 PE 签名并跳过已感染文件。

4. 文件感染技术：
   - 在现有节或新增节中加入病毒代码；
   - 修改入口点 AddressOfEntryPoint 指向病毒；
   - 执行后跳回原入口点；
   - 加入感染标记防止重复感染。

映射头：

AddressOfEntryPoint：程序启动执行的第一条指令地址（RVA），病毒常改此实现感染。
• ImageBase：PE 文件希望加载的内存基地址（用于计算真正入口地址）。
• SectionAlignment/FileAlignment：节的对齐方式（内存/文件）。
• SizeOfImage：映像在内存中的总大小，新增节必须修改。
• SizeOfHeaders：所有 PE 头 + 节表大小。

Win11采用了哪些安全设计？（起码列举4点）

1. 硬件根信任 + TPM 2.0 + Secured-core PC
2. 基于硬件-虚拟化隔离（Virtualisation-based Security, VBS）与内核保护
3. 无密码/凭证保护与身份认证安全
4. 应用控制与最小权限原则

TPM2.0简介，依托于TPM2.0，可以实现哪些安全功能?

TPM 2.0 是一个安全芯片，用于作为硬件根信任，用来安全地存储密钥、设备身份和启动测量值。
依托 TPM 2.0，可以实现：

1. Secure Boot / Measured Boot（防篡改启动）
2. BitLocker 全盘加密密钥保护
3. Windows Hello 生物识别密钥保护
4. 证书与私钥的安全存储
5. 远程证明（设备完整性验证）
6. 硬件级加密、签名与随机数生成